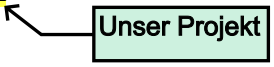
Task 4 | OSS Project Analysis (Group Work)

Due: June 11, 2026

Each group analyzes one real-world open-source Java project with Semgrep and Joern. Your professor assigns one of the following projects to your group:

#	Project	Repository
1	Apache Log4j 2	`apache/logging-log4j2`
2	Jenkins Core	`jenkinsci/jenkins`
3	Apache Kafka	`apache/kafka`



Clone the current stable release (not a historical vulnerable version).

Coordinated Disclosure

If you discover a critical, previously unknown vulnerability: **contact the course instructor before sharing the finding with anyone.** We will follow coordinated disclosure principles. New vulnerabilities will not be presented in class. If in doubt a finding qualifies, contact me in the previous tutorial.

Analysis

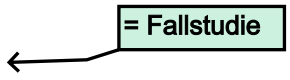
Semgrep scan:

```
semgrep --config p/java --config p/owasp <source-directory>/
```

Document: number of findings, severity distribution, top rule IDs.

Joern analysis:

Parse the project into a CPG. Write at least 3 custom queries targeting different vulnerability classes (e.g., SQL injection, command injection, deserialization, SSRF). Reuse and adapt the query patterns from Vorlesung 4 and Task 3.



Triage

For each finding, classify as:

- **True Positive (TP):** real vulnerability or confirmed bad practice.
- **False Positive (FP):** safe code incorrectly flagged. Explain why.
- **Unclear:** cannot determine without runtime context. State what is missing.

Document your top 5 findings in a table: file, line, tool, rule/query, severity, TP/FP/unclear, justification.

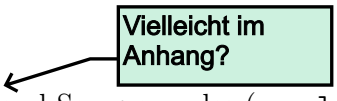
Presentation

10–15 minutes per group, presented to the other students. Content:

- Project overview (purpose, size, language breakdown).
- Tool setup experience (parsing time, issues encountered).
- Top findings with triage reasoning.

- False positive rate and patterns observed.
- What the tools could not find (limitations encountered in practice).

Submit



- Joern queries (`.sc`) and Semgrep rules (`.yaml`, if custom rules were written).
- Findings report (table as described above).
- Presentation slides.